

## AMERICAN LATIN CLASS ATTENDANCE SYSTEM

# Security Guide

## Table of Contents

### Security Guide

#### Authentication And Authorization

#### Session Security

#### Input Validation

#### Network And CORS

#### Secrets

#### Logging

# Security Guide

## Authentication And Authorization

- Google identity is verified server-side in production.
- Application roles are internal and are not derived from Google profile data.
- Protected endpoints use `requireAuth` or `allowRoles`.
- Role updates are restricted to `Admin` and are audited.

## Session Security

- Session cookie is HttpOnly and SameSite strict.
- Secure cookie flag is enabled in production.
- Only token hashes are stored server-side.
- Logout revokes the server-side session.
- Private pages and APIs send no-store cache headers.

## Input Validation

- Zod validators centralize request body validation.
- Invalid bodies return `422`.
- Business conflicts return `409`.

## Network And CORS

- `CORS_ORIGINS` must list only trusted frontend origins.
- Auth login route is rate limited by `AUTH_RATE_LIMIT_MAX`.
- In AWS, RDS must only accept traffic from API security groups.

## Secrets

- No real secrets are committed.
- Production secrets belong in AWS Systems Manager Parameter Store or Secrets Manager.
- `.env.example` contains placeholders only.

## Logging

- API responses do not expose stack traces.
- Audit logs store action metadata but should not store raw tokens or sensitive evidence contents.